Sierra Monitor / MSA FieldServer protocol gateways

Sierra Monitor / MSA FieldServer protocol gateways — Firmware Attack Surface & Detection Brief

Scope: CVE and public-advisory (OSINT) research only — **no firmware or software has been acquired or extracted for this vendor.** Every finding below comes from public vulnerability disclosures (NVD, CISA ICS advisories, vendor PSIRT) and product documentation. CVE IDs listed in the Confirmed table were each independently re-verified against NVD/CISA/vendor records before inclusion; candidate IDs that could not be confirmed were dropped, not guessed.

Identity

Field	Value
Census / OUI string	`Sierra Monitor Corp.`
Operating company	MSA Safety Incorporated (Mine Safety Appliances), Cranberry Township, PA — operates the former Sierra Monitor Corporation (Milpitas, CA) and its FieldServer product line, acquired May 2019.
OT devices (ARNG census)	15 across 3 states
Genuine OT vendor?	Yes
Purdue placement	Level 1-2 primarily: protocol gateways bridge field controllers/sensors (L1) to supervisory BAS/BMS/SCADA head-ends (L2), i.e. they straddle the L1/L2 boundary. When FieldServer Manager cloud management is enabled, a management plane extends to Level 3.5/4 (outbound to MSA cloud). FGFD gas/flame controllers are Level 1 safety instrumentation.

Identity note. The census OUI/registered string "Sierra Monitor Corp." is an acquisition lineage, NOT an OUI artifact or IT-vendor misfile. Sierra Monitor Corporation (Milpitas, CA) was a maker of protocol gateways (FieldServer) and fixed gas & flame detection (FGFD) instruments. MSA Safety acquired it in a deal announced 2019-03-29 (~$33M) and completed 2019-05-21; the products are now branded MSA FieldServer / MSA Safety. NIC OUIs and device labels in the field still read "Sierra Monitor," so the census string correctly identifies a genuine OT edge device whose vendor-of-record is now MSA. CRITICAL disambiguation: Sierra Monitor is a DIFFERENT company from "Sierra Wireless" (AirLink/ALEOS cellular routers) and from "Sierra Wireless/Semtech"; do not conflate their CVEs/advisories.

Product lines & OT relevance

High. Sierra Monitor/MSA FieldServer devices are purpose-built OT protocol gateways that translate between building-automation and industrial fieldbus protocols (BACnet, Modbus, LonWorks, M-Bus, KNX, SNMP, EtherNet/IP, Metasys N2, etc.), plus FGFD gas/flame safety controllers. In a National Guard facility context these sit at the HVAC/BMS, generator, metering, and life-safety boundary, bridging field controllers to supervisory/BMS head-ends and (optionally) to MSA's cloud. 15 devices across 3 states strongly implies facility BAS/mechanical integration gateways rather than IT gear.

- FieldServer multiport protocol gateways (e.g. FS-B35xx family) - 140+ BAS/industrial protocol translation
- QuickServer compact gateways (FS-QS-1XXX / 2XX0 / 3X10 series) - BACnet/Modbus/LonWorks/SNMP translation with embedded FS-GUI web configurator
- ProtoNode / ProtoCessor / ProtoAir OEM embedded gateway modules (ProtoAir adds cellular/Wi-Fi) - integrated into third-party HVAC/boiler/chiller/metering OEM equipment
- FieldServer Manager cloud platform (formerly SMC Cloud / 'grid') - remote device management, firmware distribution, diagnostics
- Sentry IT / Sentry fixed gas & flame detection (FGFD) controllers and gas-detection instruments (legacy Sierra Monitor line, now MSA FGFD)

Attack surface

- Embedded web GUI (FS-GUI / Web Configurator) over HTTP tcp/80 and HTTPS tcp/443 - primary admin plane; WebSocket-based UI
- Default credentials: username 'admin' (lowercase) with per-device default password printed on the physical label / QR code; older/mismanaged units commonly left at default. 5 failed attempts triggers a 10-minute lockout. Lost default = factory return.
- Default IP 192.168.2.101 (discovery range .100/.101) if DHCP not configured
- FieldServer Toolbox (Windows) uses a UDP broadcast discovery protocol to enumerate devices on the subnet and launches into the FS-GUI
- Unauthenticated-by-design fieldbus listeners: BACnet/IP udp/47808 (0xBAC0), Modbus TCP tcp/502, EtherNet/IP tcp/44818 + udp/2222, SNMP v1/v2c udp/161 + traps udp/162, KNXnet/IP udp/3671, M-Bus, LonWorks/FTT-10
- Shared internal administrative account with a static shared secret identical across all devices (CVE-2024-45494) - a single leaked secret compromises every unit in the fleet
- Network-reachable bypass of the 'local-only' internal-user login restriction (CVE-2024-45493) - internal accounts authenticable from the network
- Cross-origin WebSocket hijacking in the web UI (CVE-2024-45495)
- Outbound cloud connectivity to MSA FieldServer Manager / SMC Cloud (dual-Ethernet models expose a dedicated cloud port) - an egress path off the OT segment
- Firmware/config update path via web GUI and cloud - unsigned/legacy firmware handling on <7.0.0 builds

Confirmed CVEs / advisories

Each row was re-verified against an authoritative record (URL given). This is the public disclosure history, not an exhaustive list.

CVE / advisory	Applies to	Summary	Source
CVE-2024-45494	Directly affects the FieldServer Gateway product line that the 'Sierra Monitor Corp.' cens	MSA FieldServer Gateway 5.0.0 through 6.5.2 ships an internally-used shared administrative account on all devices whose authentication relies on a static shared	https://nvd.nist.gov/vuln/detail/CVE-2024-45494
CVE-2024-45493	Same FieldServer Gateway product line as the censused Sierra Monitor/MSA devices; turns an	MSA FieldServer Gateway 5.0.0 through 6.5.2 - internal user accounts intended to be restricted to local-only login can be bypassed and authenticated from the ne	https://nvd.nist.gov/vuln/detail/CVE-2024-45493
CVE-2024-45495	Affects the FieldServer Gateway web GUI present on the censused devices; an operator visit	MSA FieldServer Gateway 5.0.0 through 6.5.2 allows cross-origin WebSocket hijacking in the web UI. CWE-346 (Origin Validation Error). CVSS 3.1 base 4.3 (AV:N/AC	https://nvd.nist.gov/vuln/detail/CVE-2024-45495

Detection guidance

- Asset-inventory the fleet: match the Sierra Monitor OUI on L2 MAC tables and run FieldServer Toolbox UDP discovery to confirm count vs the 15 censused; flag any device reporting firmware < 7.0.0 (pre-fix for the 2024 CVE cluster)
- Restrict and monitor the admin plane: allow tcp/80 and tcp/443 to each gateway ONLY from a named BMS engineering/jump host (allowlist by source IP on a management VLAN); alert on any other source touching the web GUI, and on WebSocket upgrade requests with unexpected Origin headers (CVE-2024-45495)
- Baseline fieldbus talkers and alert on deviation: BACnet/IP udp/47808 (new Who-Is scanners/foreign-device registration), Modbus TCP tcp/502 (new masters / write function codes 5/6/15/16), EtherNet/IP tcp/44818+udp/2222, SNMP udp/161-162, KNX udp/3671 - these should only involve known BAS controllers
- Egress control: block or explicitly allowlist outbound TLS from gateways to MSA FieldServer Manager / SMC Cloud; any other outbound from a gateway is suspicious (gateways should not browse the internet)
- Collect web-GUI authentication events where available (failed-login and 10-minute lockout events indicate password spraying against 'admin'); forward device syslog if the model supports it
- Deploy Zeek/network-flow (NetFlow/IPFIX) on the OT boundary to log the above ports; use firewall deny-logs at the IT/OT boundary to catch inbound attempts from enterprise/internet toward gateway management ports
- Network IDS/allowlisting rule: deny inbound to gateways from any non-OT segment; permit only the specific BAS head-end(s) and the single Toolbox management host

Acquisition status

We currently hold NONE for this vendor; this brief is OSINT-only. Firmware binaries are gated: FieldServer/QuickServer firmware is distributed through MSA's FieldServer Manager cloud portal and the device web-GUI update function, and via MSA support (us.msasafety.com/fieldserver) - generally requiring vendor engagement/registration rather than an open download. NOT gated and freely available: the FieldServer Toolbox diagnostic utility, QuickServer start-up guides, operating manuals, protocol-driver/config-profile files, and model datasheets are publicly mirrored by Chipkin Automation Systems (store.chipkin.com, cdn.chipkin.com), the long-time FieldServer distributor/support partner; the 'Security Advisory - FieldServer Gateway' (Nov 2024) PDF is a public tokenized download at us.msasafety.com/security-notices. Practical acquisition of actual firmware for differential analysis would require an MSA support relationship or extraction from a physical unit; config profiles and the Toolbox can be pulled openly from Chipkin.

Notes

All three CVEs were verified in THIS research by fetching NVD's authoritative REST API (services.nvd.nist.gov/rest/json/cves/2.0?cveId=...), which returned matching product/version/CWE/CVSS for each; the human-readable NVD URLs are cited above. No fabricated or half-remembered IDs are included. The candidate CVE-2018-7649 surfaced in search but was verified to be a DIFFERENT product (fibranet 'Monitorix' XSS) and is excluded. No dedicated CISA ICSA advisory was found for FieldServer (the Dec-10-2024 CISA roundup did not include MSA); the coordinating public reference is MSA's own security notice (us.msasafety.com/security-notices, 'Security Advisory - FieldServer Gateway', Nov 2024), listed as the reference in each NVD record alongside us.msasafety.com/fieldserver. All three flaws share the 5.0.0-6.5.2 affected range with the fix in 7.0.0, so a single remediation (upgrade to >=7.0.0 + rotate credentials + segment) addresses the cluster. Firmware version triage of the 15 devices against 7.0.0 is the highest-value first action. Remember Sierra Monitor != Sierra Wireless when triaging future advisories.

Status

Item	State
Firmware/software acquired	**No** — OSINT/advisory only
Confirmed CVEs	3 (independently re-verified)
Behavioural baseline	None — no samples held
Next step	CISA/PSIRT deep pass; attempt firmware acquisition

Generated 2026-10-26 from the ot-vendor-briefs workflow (12 researchers + adversarial CVE verification). Device counts from the 2026-10-22 ARNG OT census.